SHIVA ZEN

Sistema de Gestão para Clínica de Estética

Jaqueline Aranha Estética

Documento de Especificação de Requisitos e Modelagem UML

Versão 2.3 | 28/10/2026

Sumário

Atualize este campo no Word (Ctrl+A, F9) para gerar o sumário.

1. Introdução

1.1 Objetivo

Este documento especifica os requisitos funcionais e não funcionais, as regras de negócio e a modelagem UML do sistema Shiva Zen — plataforma web de gestão da clínica de estética Jaqueline Aranha. O conteúdo foi derivado diretamente do código-fonte da aplicação (Django 5.2, migrations até 0061), garantindo aderência ao comportamento realmente implementado.

1.2 Escopo

O sistema cobre o agendamento online público (sem senha: a cliente é identificada pelo celular, confirmado por código OTP via SMS em todo agendamento), com aceite da Política de Privacidade, consentimento para dado de saúde, termos do procedimento e autorizações de comunicação com histórico; a área "Meus agendamentos" (reagendar e cancelar); o portal do profissional; o painel administrativo (agenda com grade e exceções, agendamento interno, clientes, prontuário com histórico, pacotes, promoções, comissões em livro-razão, NPS e depoimentos, termos, auditoria); rotinas automáticas (fila de e-mail, lembrete D-1, NPS, pacotes, aniversário, limpeza de status, retenção LGPD) e integrações externas (SMS Zenvia, WhatsApp Meta, e-mail, Google Calendar, Cloudflare Turnstile, Sentry).

1.3 Visão geral da arquitetura

Aplicação Django monolítica renderizada no servidor e servida por gunicorn (1 worker × 4 threads) em contêiner Docker no Railway, com PostgreSQL 18 como banco principal: 36 tabelas no padrão SQL, invariantes garantidas por EXCLUDE, CHECK, UNIQUE parciais e triggers, trilha de alterações por trigger, funções e views de relatório e procedures que concentram a retenção LGPD; o dado de saúde é gravado cifrado. Não há Celery: os jobs periódicos são funções disparadas por um cron externo via HTTP autenticado e o e-mail transacional é uma fila na própria tabela de notificações; cache e sessão são locais, com Redis opcional. O front-end usa Vite, Tailwind CSS v4, Alpine.js (build CSP) e componentes django-cotton, com PWA. A regra de negócio reside nos serviços — services/agenda concentra as regras de horário e services/atendimento os efeitos de cada mudança de status, aplicados na mesma transação da máquina de estados (FSM) do atendimento. Detalhes nas seções 8 e 10.

2. Atores do Sistema

Atores identificados a partir dos papéis de acesso e dos fluxos públicos e internos.

Ator	Descrição
Visitante / Cliente (público, sem login)	Navega no site e agenda sem conta: a identidade é o celular, confirmado por código SMS em todo agendamento. Aceita a Política de Privacidade, o consentimento para dado de saúde e os termos do procedimento, escolhe as autorizações de comunicação, entra na lista de espera e responde NPS por link. Precisa ter 18 anos ou mais.
Cliente cadastrada	Cliente com cadastro ativo (mesmo celular). Entra em "Meus agendamentos" por celular ou e-mail (o código vai ao celular do cadastro), reagenda (até 24 h antes) e cancela pela sessão do portal, confirma presença pelo link do lembrete D-1, aceita termos pendentes e exerce os direitos LGPD (exportar dados, descadastrar).
Profissional	Usuário PROFISSIONAL vinculado a um profissional ativo, com 2FA obrigatório em produção. Usa o portal /profissional/: agenda própria, aprova/rejeita os próprios pedidos, marca realizado (com termo aceito ou override auditado), anota a sessão e lê a ficha só das clientes com vínculo. Gera o link do feed iCal, conecta o Google Calendar e ativa o push.
Administrador (ADMIN)	Usuário ADMIN (is_staff), com 2FA obrigatório. Painel completo, incluindo as tarefas de recepção: agenda, agendamento interno, aprovação, clientes, autorizações de comunicação e prontuário, profissionais e exceções de agenda, catálogo, pacotes, promoções, financeiro, comissões, NPS e depoimentos, lista de espera, formulários e termos, usuários, configurações, Branding e auditoria.
Sistema / Cron externo	Agendador externo (cron-job.org ou Railway Cron) que chama POST /cron/run/<job>/ com o header X-Cron-Token, ou o comando rodar_job no servidor: fila de e-mail, lembrete D-1, NPS, alerta de detrator, pacotes, aniversário, limpeza de status, retenção LGPD, housekeeping e feriados. Sem Celery: o job roda dentro do request.
Serviços externos	Zenvia (SMS/OTP e status de entrega), WhatsApp Cloud API (lembrete, NPS, aviso de vaga e respostas via webhook assinado), provedor de e-mail, Cloudflare Turnstile, Google Calendar e Sentry.

3. Requisitos Funcionais

ID	Ator	Descrição
RF01	Cliente (público)	Consultar serviços, equipe, promoções (com o mesmo preço do agendamento), galeria e depoimentos autorizados.
RF02	Cliente (público)	Agendar online escolhendo procedimento, data/horário e profissional, confirmando o celular com código SMS.
RF03	Cliente (público)	No agendamento, aceitar a Política de Privacidade e os termos do procedimento, consentir o uso do dado de saúde (termo SAÚDE), escolher as autorizações de comunicação e responder a ficha de anamnese.
RF04	Cliente (público)	Acessar "Meus agendamentos" com celular ou e-mail cadastrado (código sempre ao celular) e ver agendamentos futuros e passados.
RF05	Cliente (público)	Reagendar um atendimento até 24 h antes pelo portal, escolhendo novo horário disponível.
RF06	Cliente (público)	Cancelar um atendimento futuro pelo portal.
RF07	Cliente (público)	Confirmar presença ou cancelar pelo link do lembrete D-1 do WhatsApp.
RF08	Cliente (público)	Aceitar termos pendentes pelo link do atendimento.
RF09	Cliente (público)	Entrar na lista de espera e receber aviso de vaga por e-mail/WhatsApp.
RF10	Cliente (público)	Responder o NPS (0–10) e autorizar a publicação do depoimento.
RF11	Cliente (público)	Responder ficha de anamnese por link, com consentimento para dado de saúde.
RF12	Cliente (público)	Baixar os próprios dados (DSAR) com código SMS, descadastrar-se de marketing e pesquisas por link e registrar o aviso de cookies.
RF13	Sistema	Oferecer o WhatsApp da clínica como caminho de agendamento quando o SMS não estiver disponível.
RF14	Equipe	Entrar com e-mail e senha, cadastrar e validar 2FA (obrigatório para ADMIN e PROFISSIONAL em produção), gerar códigos de backup e redefinir a senha por link.
RF15	ADMIN	Aprovar ou rejeitar pedidos PENDENTES (individual ou em lote), com e-mail à cliente.
RF16	ADMIN (recepção)	Agendar pelo painel para cliente existente ou nova, com os horários do mesmo cálculo do site.
RF17	ADMIN	Operar a agenda: lista com filtros por dia, calendário com arrastar-e-soltar (motivo detalhado da recusa), mudança de status pela FSM, valor cobrado, link do termo e override "Realizado sem termo aceito".
RF18	Profissional	Usar o portal: agenda do dia/semana, pedidos pendentes (aprovar/rejeitar), marcar realizado, anotar a sessão, ver alertas de saúde e a ficha das clientes com vínculo, ativar push.
RF19	ADMIN / Profissional	Registrar e consultar o prontuário (com as perguntas do formulário PRONTUARIO) e o histórico de versões, e anotar as sessões.
RF20	ADMIN	Gerir clientes: busca sem acento, ficha com alertas, pacotes, histórico, autorizações de comunicação e edição validada (telefone/CPF/e-mail únicos).
RF21	ADMIN	Gerir profissionais (grade semanal, exceções — folga, horário diferente, bloqueio —, antecedências, novo link do feed iCal), procedimentos, preços, habilitações e bloqueios de agenda (inclusive para todos os profissionais).
RF22	ADMIN	Gerir pacotes: criar/editar o catálogo, vender (itens congelados na venda), acompanhar saldo e validade, cancelar com valor devolvido.
RF23	ADMIN	Gerir promoções e disparar e-mail de promoção para clientes com consentimento.
RF24	ADMIN	Acompanhar dashboard e financeiro (faturamento, faltas, rankings), comissões em livro-razão (créditos, pagamentos, estornos e saldo por profissional), pagar comissões e exportar relatório em Excel.
RF25	ADMIN	Acompanhar o NPS e aprovar ou retirar depoimentos do site.
RF26	ADMIN	Ver a lista de espera e avisar manualmente a cliente de uma vaga.
RF27	ADMIN	Gerir formulários (anamnese, pesquisa e perguntas do prontuário) e termos versionados (LGPD, saúde, procedimento), e acompanhar a conformidade dos aceites.

RF28	ADMIN	Gerir usuários da equipe, configurações, Branding (contatos e marca), notificações, pré-visualizar e-mails e consultar a auditoria.
RF29	Sistema	Executar jobs periódicos por cron HTTP autenticado ou pelo comando rodar_job: fila de e-mail, lembrete D-1, NPS, alerta de detrator, pacotes, aniversário, limpeza de status, retenção LGPD, housekeeping e feriados.
RF30	Sistema	Criar automaticamente o retorno gratuito quando o procedimento exige.
RF31	Sistema	Ao mudar o status do atendimento, aplicar na mesma transação: débito de sessão de pacote, comissão (crédito/estorno), cashback, faltas, retorno e aviso à lista de espera.
RF32	Sistema externo	Receber webhooks do WhatsApp (resposta de NPS) e da Zenvia (status de SMS), autenticados.
RF33	ADMIN	Na ficha da cliente, ver as autorizações de comunicação por canal, revogá-las a pedido e registrar autorização com justificativa (histórico preservado).
RF34	Profissional	Gerar o link do feed iCal da própria agenda (exibido uma única vez) e conectar o Google Calendar.
RF35	Sistema	Enfileirar os e-mails transacionais na própria notificação e reenviá-los com espera crescente até 5 tentativas.
RF36	Sistema	Registrar automaticamente, por trigger, toda alteração das tabelas sensíveis com autor, IP e origem.

4. Requisitos Não Funcionais

ID	Categoria	Descrição
RNF01	Segurança	Content-Security-Policy com nonce por request, sem unsafe-inline em script-src/style-src e sem handlers inline; libs de CDN só por caminho versionado e com SRI; frame-ancestors none (exceto o widget).
RNF02	Segurança	HTTPS obrigatório com HSTS de 1 ano (preload), X-Frame-Options DENY, nosniff, COOP/CORP, Permissions-Policy e cookies HttpOnly/SameSite/Secure.
RNF03	Segurança	2FA TOTP obrigatório para ADMIN e PROFISSIONAL em produção, conferido a cada request no painel, portal, Django admin e push; códigos de backup; sem tela de login paralela; recuperação só por comando no servidor.
RNF04	Segurança	OTP com HMAC-SHA256 e a SECRET_KEY, comparação em tempo constante, 5 tentativas, propósitos isolados e desafio preso ao telefone.
RNF05	Segurança	Rate-limit em camadas: cotas de SMS (telefone, IP, global), limites por IP nos endpoints públicos, django-axes no login; captcha Turnstile no pedido de código.
RNF06	Privacidade	Áreas privadas sem cache no navegador (no-store), Referrer-Policy no-referrer nas rotas com token, X-Robots-Tag noindex nas privadas, Clear-Site-Data no logout; links públicos guardam só o SHA-256 do token; tokens redigidos no access log e no Sentry.
RNF07	Segurança	Segredos só em variáveis de ambiente; SECRET_KEY obrigatória fora de DEBUG; DJANGO_ENV inválido derruba o boot; system checks (aranha.W001–W014) apontam configuração de produção faltando.
RNF08	Confiabilidade	Canais de mensagem falham fechado: sem credencial nada é enviado nem marcado como enviado; I/O externo só após o commit; e-mail transacional em fila no banco com reenvio (sem Celery, nada roda em segundo plano sem rastro).
RNF09	LGPD	Autorizações de comunicação por finalidade × canal em histórico append-only (texto exibido, IP, navegador, autor); aceite da política, do termo de saúde (art. 11) e dos termos do procedimento com prova (IP, navegador, SHA-256).
RNF10	LGPD	Retenção automatizada (OTP, notificações, auditoria, trilha, links, logs de login, clientes inativas/excluídas, fichas de pedidos não realizados, lista de espera) e esquecimento com pseudonimização, executados por procedures do Postgres; inventário LGPD coluna a coluna conferido por teste.
RNF11	LGPD	Direitos do titular: acesso/portabilidade (DSAR em JSON), correção pela clínica, revogação de consentimento, anonimização.
RNF12	LGPD	Trilha de auditoria (log_auditoria) e trilha de dados (historico_alteracao, por trigger) com autor, IP e origem, ambas append-only no banco; PII mascarada em logs e no Sentry (send_default_pii=False).
RNF13	Integridade	Invariantes no banco: EXCLUDE (atendimento, grade, folgas), UNIQUE parciais, CHECKs, 46 triggers (atualizado_em, imutabilidade de ledgers, prova de aceite, termo aceito, prontuário, anotação, item de pacote, consentimento e link; validação de consumo e de comissão) e FKs PROTECT no histórico clínico/financeiro.
RNF14	Confiabilidade	Migrações aplicadas numa transação única com lock_timeout no pre-deploy (tudo ou nada); data migrations com pré-checagem que aborta listando os registros; rollback de produção por restauração do backup.
RNF15	Confiabilidade	FSM com transições validadas sob lock e auditadas; efeitos explícitos (services/atendimento) na mesma transação do status; efeitos idempotentes (1 retorno por origem, 1 consumo e 1 crédito de comissão por atendimento, cashback único).
RNF16	Desempenho	gunicorn 1 worker × 4 threads com cache local (Redis opcional para escalar); estáticos comprimidos e com hash (WhiteNoise); índices das consultas reais, busca trigram sem acento, alertas de saúde em lote, statement_timeout na conexão e consultas lentas pelo pg_stat_statements.
RNF17	Observabilidade	Healthchecks /healthz/ (liveness + build do front) e /health/ (banco, cache, front); Sentry opcional; logs JSON em produção; jobs devolvem 500 quando falham (o cron alerta).

RNF18	Qualidade	Cerca de 1.500 testes automatizados em 77 arquivos; CI com SQLite, Postgres 18 (conformidade do padrão SQL, trilha e paridade das funções com o Python), data migrations em paralelo, build do front, wizard no Chromium (Playwright), imagem Docker e pip-audit bloqueante; ruff, import-linter, mypy nos services e cobertura com catraca (≈ 87 %).
RNF19	Usabilidade	Interface pt-BR em tom de estética e bem-estar; contraste AA nos tokens, foco visível, formulários acessíveis, diálogos nativos e respeito a prefers-reduced-motion; wizard com botão Continuar operável por teclado; tema claro/escuro automático; fontes locais; PWA instalável para o site e para a equipe.
RNF20	Manutenibilidade	Camadas views → services/utils → models verificadas por import-linter; fontes únicas (services/agenda, services/atendimento, SlotService, preços, Branding, termos, consentimentos); recusas tipadas (RegraDeNegocio); Django Forms no painel; componentes cotton e Alpine CSP; documentação viva e requisitos gerados a partir de dados versionados.
RNF21	Implantação	Imagem Docker multi-stage (Node para o front, Python para a app) com dependências fixadas (requirements.lock), usuário não-root e healthcheck; deploy no Railway com pre-deploy de migração e criação do ADMIN.
RNF22	Privacidade	Dado de saúde e token OAuth cifrados em repouso na aplicação (Fernet, CHAVES_CIFRAGEM com subchave por finalidade e rotação por comando): dump ou backup sem a chave não expõe a ficha.
RNF23	Manutenibilidade	Padrão SQL em todas as tabelas (nomes snake_case PT-BR, prefixos pk_/fk_/uq_/ck_/ix_/ex_/tg_/fn_, ON DELETE real, COMMENT em toda tabela, defaults no banco), conferido por teste no pg_catalog.

5. Regras de Negócio

ID	Título	Descrição
RN01	Papéis da equipe	Usuario.papel = ADMIN, PROFISSIONAL ou RECEPCAO (CHECK). ADMIN (is_staff) tem o painel completo; PROFISSIONAL vinculado a um profissional ativo usa o portal /profissional/; RECEPCAO não tem login até existirem telas próprias. A cliente nunca é usuária.
RN02	Identidade da cliente pelo celular	A cliente não tem conta nem senha: a identidade é o telefone (só dígitos, 10–11, sem DDI), único entre clientes ativos (UNIQUE parcial). E-mail e CPF são opcionais e também únicos entre ativos. O e-mail digitado nunca é identidade.
RN03	Idade mínima	O agendamento online exige data de nascimento e idade mínima de 18 anos.
RN04	Bloqueio online por faltas	Cada falta soma em faltas_consecutivas; ao atingir o limite (Configuracao MAX_FALTAS_BLOQUEIO, padrão 3) a cliente fica bloqueada para agendar online. Comparecer (REALIZADO) zera o contador e desbloqueia. A clínica ainda pode agendar pelo painel.
RN05	Exclusão lógica da cliente	Excluir cliente é soft delete (deletado_em); exclusão física só explícita. A anonimização segue a RN40/RN41.
RN06	Fluxo do agendamento público	Procedimento → data/horário → dados + código SMS → confirmar. O servidor revalida tudo no confirmar: procedimento/profissional ativos, habilitação, data futura, feriado, slot livre para a duração inteira, ficha e aceites. Sem provedor de SMS o agendamento online fica indisponível e o botão Agendar leva ao WhatsApp.
RN07	Antecedência mínima	Por profissional: min_notice_horas (padrão 2 h, faixa 0–720).
RN08	Antecedência máxima	Por profissional: max_advance_dias (padrão 60 dias, faixa 1–365). Não há teto global.
RN09	Cálculo de disponibilidade	SlotService (fonte única): slots de 30 min a partir da grade semanal (agenda_horario) e das exceções (agenda_excecao: folga do profissional, feriado/recesso da clínica, horário diferente, bloqueios pontuais e recorrentes do profissional ou de todos), atendimentos ativos sobrepostos na duração inteira + intervalo do procedimento, antecedência mínima e máxima.
RN10	Anti double-booking	Um profissional não pode ter dois atendimentos ativos sobrepostos: trava de 30 s no cache durante a confirmação do site, SELECT FOR UPDATE em services/agenda.reservar e constraint EXCLUDE no Postgres. Corrida perdida vira HorarioIndisponivel com a mensagem "Este horário acabou de ser reservado".
RN11	Pedido público nasce PENDENTE	O agendamento público entra como PENDENTE; a clínica aprova (AGENDADO + e-mail de confirmação) ou rejeita (CANCELADO + e-mail), no painel (individual ou em lote) ou no portal do profissional. PENDENTE vencido há 24 h é cancelado pelo job de limpeza.
RN12	Agendamento interno	A recepção agenda pelo painel (cliente existente ou nova com telefone validado) pela mesma validação do site (services/agenda.validar_horario, com o motivo detalhado para a equipe: conflito, bloqueio, folga, expediente); não há OTP; o atendimento nasce AGENDADO e o valor combinado pode ser registrado.
RN13	Preço gravado com promoção da data	O atendimento grava o preço vigente na data do atendimento (profissional > base) com a promoção que vale nesse dia: valor_cobrado, valor_original, promoção e descrição. Vitrine e resumo mostram exatamente esse valor.
RN14	Aceite da Política de Privacidade	Obrigatório no agendamento; grava AceiteTermo da versão LGPD vigente com IP, navegador e SHA-256 do texto aceito.
RN15	Consentimento para dado de saúde (art. 11)	A ficha de anamnese (no wizard ou pelo link) só é gravada com a caixa de consentimento específica marcada; o aceite vira AceiteTermo da versão SAUDE vigente (IP, navegador, SHA-256 do texto) e vai também para a auditoria.
RN16	Termos de procedimento	Termos do procedimento (próprio e gerais) são aceitos no wizard; versão já aceita não é pedida de novo. Faltando aceite, o atendimento mostra "Termo pendente" e a clínica gera o link do termo, válido até o fim do atendimento. Marcar REALIZADO com termo pendente exige o override explícito "Realizado sem termo aceito", auditado.

RN17	Consentimentos de comunicação	Três autorizações por finalidade × canal — promoções por e-mail, lembrete/aviso de vaga por WhatsApp e pesquisa de satisfação por WhatsApp —, nunca pré-marcadas. Cada concessão ou revogação é uma linha nova e imutável (texto exibido, IP, navegador, autor, data); vale a mais recente; marcar de novo depois de um descadastro volta a valer. O descadastro por link revoga marketing e pesquisa e mantém o lembrete D-1. A equipe revoga a pedido da cliente e só registra autorização com justificativa.
RN18	Código OTP	Código de 6 dígitos (secrets), armazenado como HMAC-SHA256 com a SECRET_KEY, nunca em texto; validade 10 min; 5 tentativas; reenvio mínimo de 60 s; gerar um novo invalida o anterior; comparação em tempo constante.
RN19	OTP preso ao telefone	Todo agendamento público exige o código enviado ao celular informado (só celular recebe SMS). Cotas de SMS: 3/h por telefone, 10/h por IP, 60/h global, checadas antes de gerar o código. Propósitos isolados (AGENDAMENTO, LOGIN_CLIENTE, DSAR). Respostas não revelam se o telefone é cadastrado.
RN20	Máquina de estados do atendimento	PENDENTE → AGENDADO/CONFIRMADO/CANCELADO/REAGENDADO; AGENDADO → CONFIRMADO/REALIZADO/CANCELADO/FALTOU/REAGENDADO; CONFIRMADO → REALIZADO/CANCELADO/FALTOU/REAGENDADO; REALIZADO, CANCELADO, FALTOU e REAGENDADO são terminais. AGENDADO = horário aprovado; CONFIRMADO = a cliente confirmou. Os efeitos da transição (pacote, comissão, cashback, faltas, retorno, lista de espera) gravam na mesma transação do status: tudo ou nada.
RN21	Reagendamento pela cliente	Pelo portal "Meus agendamentos" (sessão do OTP, só agendamentos do telefone verificado) ou pelo link legado, até 24 h antes. services/agenda.reagendar: o antigo vira REAGENDADO antes de o novo entrar; o novo herda preço, promoção, vínculo de retorno e a ficha. Fica AGENDADO se o original estava aprovado e a profissional é a mesma; senão volta a PENDENTE.
RN22	Cancelamento pela cliente	Pelo portal (id do atendimento + sessão do OTP) ou pelo link legado, a qualquer momento antes do início, pela FSM; a trilha registra "[pela cliente]". Cancelamento feito pela clínica avisa a cliente por e-mail.
RN23	Lembrete D-1 e confirmação de presença	Às 08:00 o sistema envia WhatsApp (template aprovado) aos atendimentos AGENDADO do dia seguinte com autorização de lembrete vigente; o link (link_acesso CONFIRMAR_PRESENCA, válido até o início) permite confirmar (→ CONFIRMADO) ou cancelar, uma única vez.
RN24	Faltas	Só a equipe marca FALTOU. O job diário não marca falta: atendimentos sem desfecho vão para o log. Não há cobrança de taxa de no-show.
RN25	Retorno obrigatório (F-RET)	Procedimento com retorno obrigatório gera, ao REALIZADO, um atendimento de retorno PENDENTE com valor 0 no primeiro horário livre da janela [mínimo, máximo] a partir do meio, gravado por services/agenda.reservar. Sem horário livre, não cria. No máximo 1 retorno vivo por origem (UNIQUE). Retorno não gera comissão, cashback nem débito de pacote.
RN26	Pacotes — consumo	Sessão REALIZADA debita 1 sessão do item congelado (compra_pacote_item) do pacote que vence primeiro (1 consumo por atendimento). A validade é conferida na data da sessão. O banco garante que o consumo é de um item da mesma compra, do mesmo procedimento, nunca de retorno e só com saldo.
RN27	Pacotes — venda e ciclo de vida	A venda congela o nome e os itens (procedimento, sessões, valor unitário = valor pago ÷ sessões); o catálogo continua editável só para vendas futuras. ATIVO → FINALIZADO (todas as sessões usadas), EXPIRADO (job diário, vencimento < hoje) ou CANCELADO (valor devolvido entre 0 e o valor pago e motivo, auditados). Aviso por e-mail 7 e 1 dia antes do vencimento com saldo.
RN28	Promoções e preços	Preço versionado por vigência (data local). Promoção = desconto 0–100% XOR preço fixo (CHECK), por período; promoção geral só vale como percentual; aplica-se só quando reduz o valor e nunca deixa negativo.
RN29	Valor cobrado e faturamento	A clínica pode registrar o valor combinado (não em cancelado/faltou/reagendado, retorno ou realizado com comissão lançada). Faturamento = avulsos realizados com valor > 0 + vendas de pacote na data da

		compra (líquidas do reembolso); sessão de pacote e retorno não somam. Ticket médio e LTV pela mesma regra.
RN30	Comissão (livro-razão)	Ao REALIZADO (não em retorno) lança 1 CREDITO pela regra mais específica (profissional+procedimento > profissional > procedimento > global; empate = mais recente): percentual 0–100 ou valor fixo sobre o valor cobrado ou, em sessão de pacote, sobre o valor unitário congelado. A baixa é um PAGAMENTO e o cancelamento um ESTORNO, ambos referenciando o crédito; estornado não se paga; nada é alterado ou apagado. Status e saldo são derivados e o saldo pode ficar negativo. Regra já usada só é desativada.
RN31	Cashback por indicação	No 1º atendimento REALIZADO e pago da indicada, a indicadora recebe R$ 50,00 na carteira (idempotente); cancelamento estorna; saldo nunca negativo; ledger imutável.
RN32	Lista de espera	Um pedido pendente por cliente/procedimento/data. Quando um atendimento ativo vira CANCELADO ou REAGENDADO, os pedidos compatíveis recebem e-mail e WhatsApp (com autorização) com link para agendar, sem reserva do horário; notificado só com entrega. O e-mail digitado no formulário anônimo fica só na inscrição.
RN33	NPS	WhatsApp de NPS entre 24 h e 7 dias após o REALIZADO, com autorização de pesquisa vigente (até 3 tentativas); link válido por 7 dias; 1 avaliação por atendimento; nota 0–10. Nota ≤ 6 gera alerta por e-mail à clínica. O cálculo do NPS é único (arredondamento "meio para cima") no painel, nas views e no banco.
RN34	Depoimentos	Só aparecem no site com opt-in da cliente, aprovação da clínica, nota ≥ 9 e comentário; nome exibido abreviado; cliente excluída ou anonimizada nunca aparece.
RN35	Aniversário e promoções por e-mail	Aniversário = e-mail de felicitação sem desconto, com consentimento de marketing. Disparo de promoção: sem cupom, validade anunciada até o fim da promoção, só para quem consentiu, com link de descadastro, em lotes de 25.
RN36	Prontuário e histórico	Ficha 1:1 com campos clínicos e as perguntas do formulário PRONTUARIO (no máximo 1 ativo). Cada edição grava antes a versão anterior (histórico append-only, imutável); edição concorrente é recusada; POST parcial não apaga campos. Anotações de sessão também são append-only (correção = nova anotação).
RN37	Acesso do profissional à ficha	O profissional só lê a ficha de quem tem atendimento REALIZADO nos últimos 180 dias ou ativo entre ontem e +60 dias (escrita sem PENDENTE); ADMIN lê todas. Toda leitura, gravação e negativa é auditada.
RN38	Alertas de saúde	Alergias, contraindicações, medicamentos e respostas marcadas como alerta de saúde nas fichas aparecem como texto visível no portal, na agenda do painel e na ficha da cliente (calculados em lote); marcador "ficha pendente" quando a ficha obrigatória não foi respondida.
RN39	Termos versionados e imutáveis	1 versão ativa por escopo (LGPD e SAUDE globais; PROCEDIMENTO geral ou por procedimento). Versão com aceite não pode ser editada (model + trigger): mudar = publicar nova versão. O aceite é imutável e nunca apagado.
RN40	Retenção de dados	OTP 24 h; texto de notificação 12 meses; auditoria e trilha de dados 5 anos (prontuário 20 anos); link público vencido ou revogado 90 dias; logs de login 90 dias; cliente sem atendimento há 5 anos ou excluída há 30 dias é anonimizada, exceto com prontuário com conteúdo, pacote comprado ou atendimento realizado nos últimos 20 anos; ficha de pedido não realizado apagada após 90 dias; lista de espera vencida apagada. A escrita é das procedures do Postgres (fonte única).
RN41	Direito ao esquecimento	sp_anonimizar_cliente: anonimiza nome ([ANONIMIZADO-pk]), contatos e documentos; revoga as autorizações vigentes (histórico fica sem IP/navegador); soft delete; apaga OTPs, lista de espera, texto de notificações e fichas que não são de atendimento realizado; retira o depoimento e o comentário do NPS; revoga todos os links públicos; pseudonimiza o nome nos textos da auditoria. Atendimentos, aceites, prontuário e pacotes ficam ligados a titular não identificável.

RN42	Acesso aos dados (DSAR)	A cliente baixa os próprios dados em JSON em /lgpd/meus-dados/ com código SMS (propósito DSAR); resposta idêntica exista ou não o cadastro; ação auditada.
RN43	Auditoria e trilha de dados	Toda ação sensível grava autor (+ nome), tabela, registro, detalhes com PII mascarada e IP (LGPD art. 37), com o Ator da requisição (usuário, IP, origem). Além disso, triggers registram cada alteração das 11 tabelas sensíveis em historico_alteracao. As duas trilhas são append-only no banco.
RN44	Login da equipe e 2FA	E-mail + senha (mínimo 10, validadores do Django). 2FA TOTP obrigatório para ADMIN e PROFISSIONAL em produção (cadastro forçado após o login, conferido a cada request; válvula de emergência por variável de ambiente com aviso). Códigos de backup no painel; trocar de aparelho exige o código atual; recuperação por comando setup_2fa --force. Sessão da equipe de 8 h deslizantes; logout só via POST.
RN45	Bloqueio de login e reset de senha	django-axes bloqueia por 1 h após 5 falhas (IP + usuário); rate-limit no login. Reset de senha com token de 1 h, 3 pedidos/15 min por IP, resposta genérica; sem backend de e-mail real nada é enviado.
RN46	Exceções de agenda	Folga (do profissional ou da clínica inteira: feriado nacional/local e recesso, carregados pelo job mensal de feriados), horário diferente (1 por profissional/dia) e bloqueio (pontual ou recorrente por RRULE diária/semanal/mensal). Grade sem janelas sobrepostas e folgas do mesmo profissional sem sobreposição (EXCLUDE). Exceção inativa fica registrada e é ignorada (ex.: feriado em que a clínica abre). Eventos do Google Calendar entram como bloqueio, sem duplicar.
RN47	Links públicos	Todo link das mensagens (confirmar presença, NPS, termo, ficha, descadastro, feed iCal) é um link_acesso com finalidade e 1 alvo; o banco guarda só o SHA-256 do token. Validade por finalidade: confirmação até o início, termo até o fim do atendimento, NPS 7 dias, ficha 60 dias, descadastro e feed sem validade. Gerar novo feed revoga o anterior; a URL aparece só na geração.
RN48	Dados de saúde cifrados	Campos clínicos e respostas do prontuário, versões do prontuário, anotações de sessão, fichas de anamnese e o token do Google Calendar ficam cifrados em repouso (Fernet, chave por finalidade); a aplicação lê em claro e o banco não busca pelo conteúdo. Rotação de chave por comando.
RN49	Fila de e-mail transacional	Confirmação, cancelamento e pedido de aprovação à profissional nascem Notificacao EMAIL PENDENTE na transação de quem pediu e saem no on_commit; se falhar, o job emails reenvia com espera crescente (5/10/20/40 min) até 5 tentativas ou 48 h (→ FALHOU). A fila não guarda cópia de dado pessoal.

6. Casos de Uso

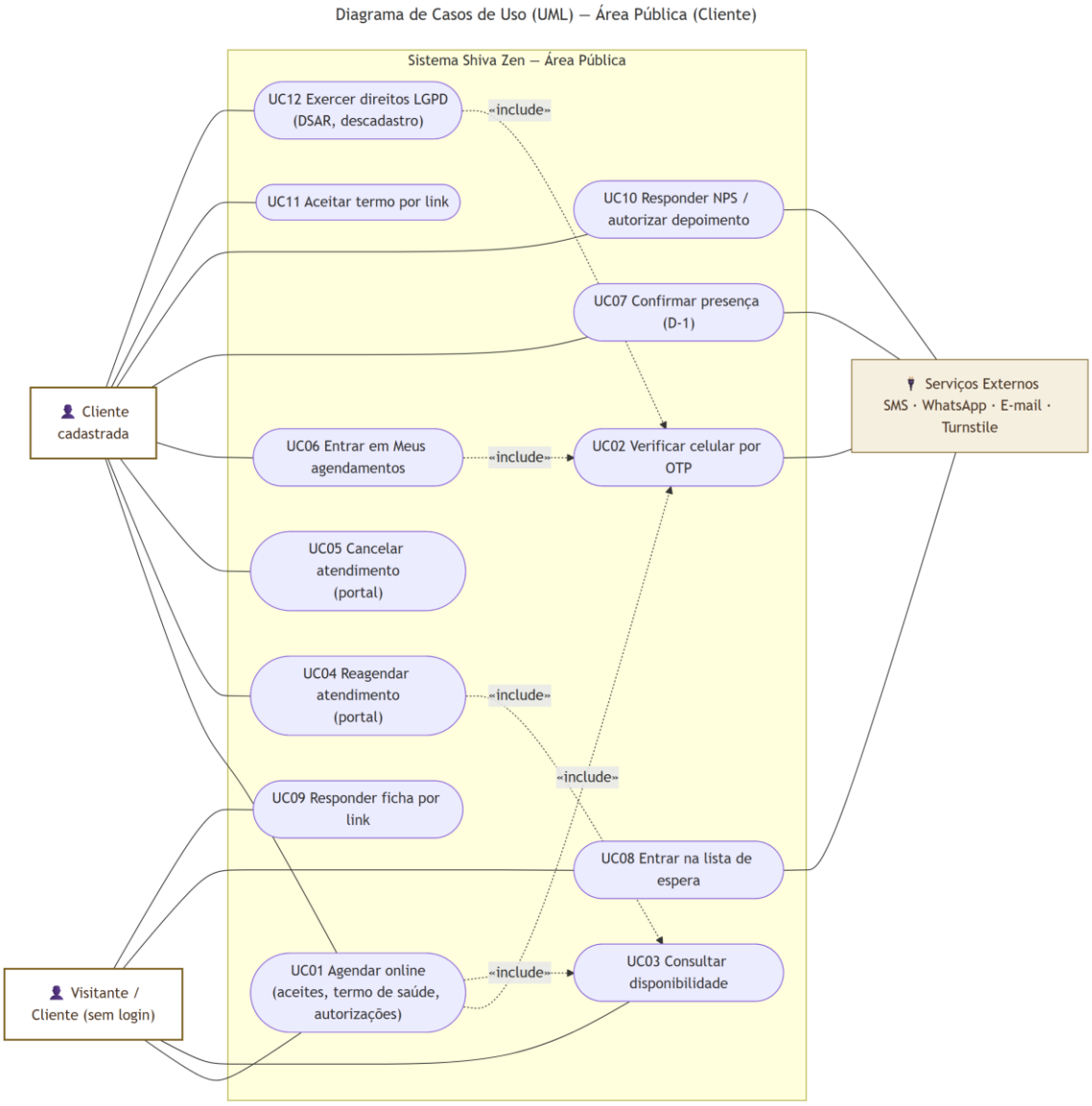


Figura 1 — Diagrama de Casos de Uso (UML): Área Pública (Cliente).

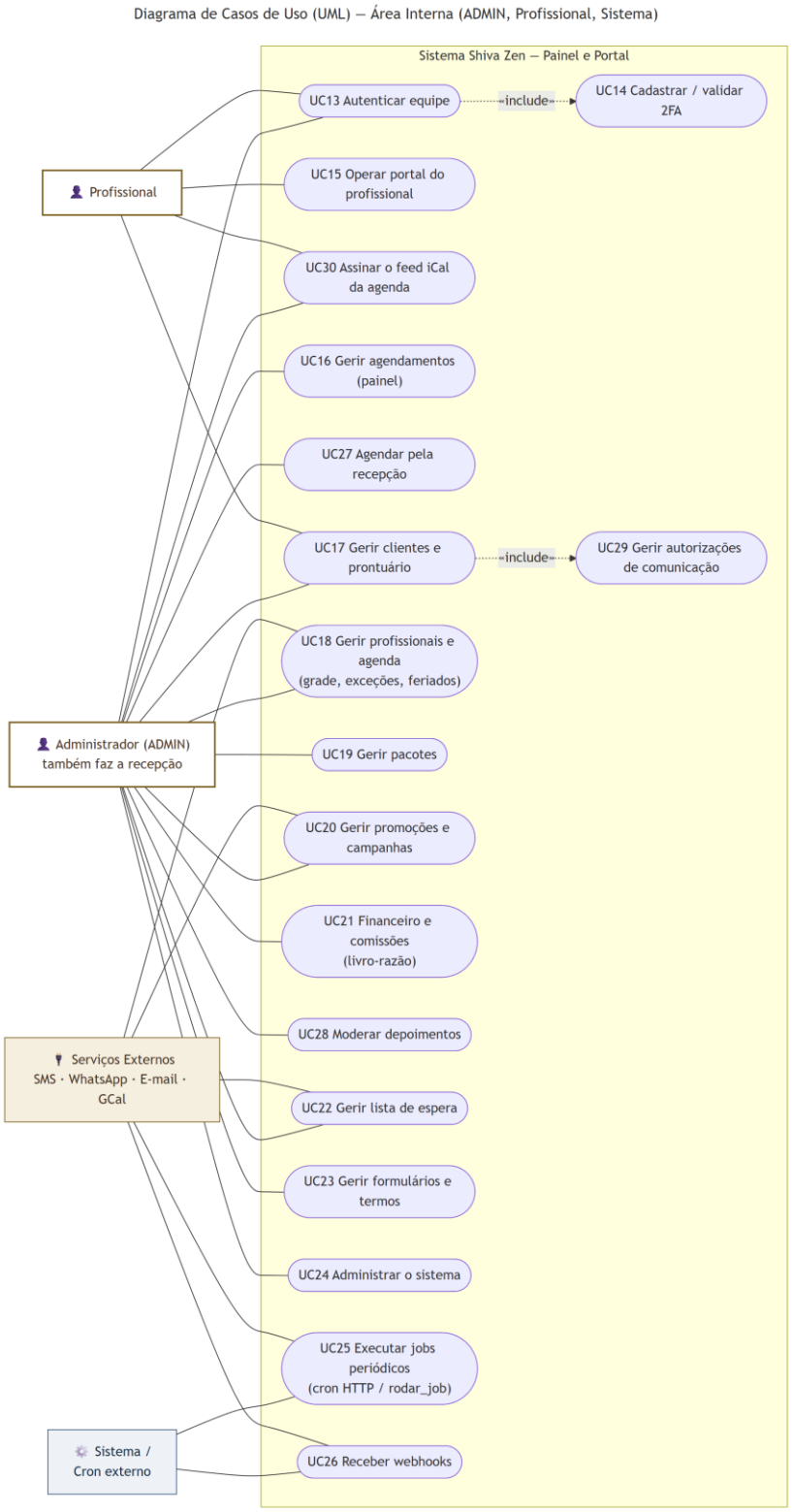


Figura 2 — Diagrama de Casos de Uso (UML): Área Interna (ADMIN, Profissional, Sistema).

6.1 Especificação dos casos de uso

ID	Caso de Uso	Atores	Fluxo principal
UC01	Agendar online	Visitante / Cliente (público, sem login), Cliente cadastrada, Serviços externos	Cliente escolhe procedimento, data/horário e profissional (botão Continuar a cada etapa), informa dados, aceita a política e os termos, consente o dado de saúde, escolhe as autorizações de comunicação e responde a ficha; confirma o celular com código SMS (UC02). O servidor revalida idade ≥ 18, aceites e o horário (services/agenda.validar_horario); trava o slot (cache + SELECT FOR UPDATE + EXCLUDE), cria/atualiza a cliente pelo telefone, registra os consentimentos (histórico), grava o atendimento PENDENTE com o preço da data (services/agenda.reservar), os aceites com prova (LGPD, SAÚDE, procedimento) e a ficha cifrada; o pedido de aprovação à profissional entra na fila de e-mail e o push sai no on_commit.
UC02	Verificar celular por OTP	Visitante / Cliente (público, sem login), Cliente cadastrada, Serviços externos	Cliente informa o celular; o sistema valida o captcha (se configurado), recusa telefone fixo, checa intervalo e cotas de SMS, gera o código (HMAC) e envia pela Zenvia. A cliente digita o código; o sistema confere (5 tentativas) e marca o telefone como verificado na sessão por 30 min, devolvendo o pré-preenchimento do cadastro daquele telefone.
UC03	Consultar disponibilidade	Visitante / Cliente (público, sem login)	O wizard consulta dias do mês e horários livres; o SlotService calcula os slots de 30 min por profissional a partir da grade semanal e das exceções (folga, feriado/recesso, horário diferente, bloqueios), atendimentos, intervalo do procedimento e antecedências.
UC04	Reagendar atendimento	Cliente cadastrada	Pelo portal (id + sessão do OTP, só agendamentos do telefone verificado) ou pelo link legado: exige ≥ 24 h de antecedência; escolhe novo horário (UC03); services/agenda.reagendar marca o antigo REAGENDADO e cria o novo com preço, retorno e ficha; fica AGENDADO se já aprovado e com a mesma profissional, senão PENDENTE.
UC05	Cancelar atendimento	Cliente cadastrada	Pelo portal (id + sessão do OTP) ou pelo link legado: atendimento ativo e futuro vai para CANCELADO pela FSM (trilha "[pela cliente]"); a vaga é oferecida à lista de espera.
UC06	Entrar em Meus agendamentos	Cliente cadastrada, Serviços externos	Cliente informa celular ou e-mail; se houver cadastro, o código vai ao celular do cadastro (resposta sempre igual); após o código, sessão de 1 h presa ao telefone com agendamentos futuros e passados, reagendar e cancelar.
UC07	Confirmar presença	Cliente cadastrada	Pelo link do lembrete D-1 (WhatsApp; link_acesso válido até o início): confirmar (AGENDADO → CONFIRMADO) ou cancelar, uma única vez.
UC08	Entrar na lista de espera	Visitante / Cliente (público, sem login)	Informa nome, celular, procedimento, data, turno/profissional e e-mail opcional; sistema normaliza o telefone e registra o pedido (e-mail só na inscrição). Quando uma vaga compatível abre, recebe aviso por e-mail/WhatsApp.
UC09	Responder ficha de anamnese por link	Visitante / Cliente (público, sem login)	Pelo link (60 dias): responde a ficha; para ficha de saúde marca o consentimento do art. 11 (aceite do termo SAÚDE com prova); respostas validadas contra o schema e gravadas cifradas; uma resposta por link. Rota

			mantida, hoje sem produtor de link.
UC10	Responder NPS	Cliente cadastrada, Serviços externos	Pelo link (7 dias) ou respondendo o WhatsApp: nota 0–10, comentário e autorização do depoimento; uma avaliação por atendimento.
UC11	Aceitar termo por link	Cliente cadastrada	Pelo link do atendimento (link_acesso TERMO, válido até o fim dele): lê e aceita os termos pendentes; o aceite grava IP, navegador e SHA-256 do texto.
UC12	Exercer direitos LGPD	Cliente cadastrada, Serviços externos	Baixar os dados em JSON após código SMS (DSAR: cadastro, consentimentos com histórico, atendimentos, fichas, prontuário, aceites, NPS, pacotes, carteira), descadastrar-se por link (revoga marketing e pesquisa) e registrar o aviso de cookies.
UC13	Autenticar equipe	Administrador (ADMIN), Profissional	Login por e-mail/senha com rate-limit e django-axes; sem 2FA cadastrado vai ao cadastro obrigatório; com 2FA passa pelo desafio (UC14); reset de senha por link (1 h). Logout só via POST.
UC14	Cadastrar / validar 2FA	Administrador (ADMIN), Profissional	Cadastro por QR (SVG) e confirmação do primeiro código; desafio a cada sessão (TOTP ou código de backup); códigos de backup gerados no painel; trocar de aparelho exige o código atual.
UC15	Operar o portal do profissional	Profissional	Agenda do dia/semana e pedidos pendentes com alertas de saúde; aprovar/rejeitar; marcar realizado (termo aceito ou override auditado); anotar a sessão; abrir a ficha quando há vínculo.
UC16	Gerir agendamentos no painel	Administrador (ADMIN)	Lista com filtros por dia e marcadores (termo pendente, ficha pendente, alertas); aprovar/rejeitar individual ou em lote (e-mail pela fila); mudar status pela FSM (409 sem termo, salvo override); calendário com arrastar-e-soltar (services/agenda.mover, motivo detalhado da recusa); valor cobrado; link do termo.
UC17	Gerir clientes e prontuário	Administrador (ADMIN), Profissional	Ficha da cliente (dados validados, alertas, pacotes, histórico, autorizações de comunicação); prontuário com as perguntas do formulário PRONTUARIO, histórico de versões, trava de edição concorrente e trilha de leitura; anotações de sessão append-only. Conteúdo clínico cifrado.
UC18	Gerir profissionais e disponibilidade	Administrador (ADMIN), Serviços externos	Profissionais (grade semanal, antecedências, habilitações, preços), exceções de agenda (folga, horário diferente, bloqueio pontual ou recorrente, inclusive para todos), feriados e recessos, procedimentos, novo link do feed iCal e conexão com o Google Calendar.
UC19	Gerir pacotes	Administrador (ADMIN)	Criar/editar pacotes do catálogo (vale para vendas futuras), vender a uma cliente (itens congelados com valor unitário), acompanhar saldo/validade e cancelar com valor devolvido.
UC20	Gerir promoções e campanhas	Administrador (ADMIN), Serviços externos	CRUD de promoções (percentual XOR preço fixo, período) e disparo de e-mail em lotes para clientes com consentimento, sem cupom.
UC21	Financeiro e comissões	Administrador (ADMIN)	Dashboard e financeiro (faturamento de avulsos + vendas de pacote líquidas, faltas, rankings, ticket médio); comissões em livro-razão (créditos, pagamentos, estornos, saldo por profissional — pode ficar negativo), pagar um crédito e exportar em Excel.
UC22	Gerir lista de espera	Administrador (ADMIN), Serviços externos	Ver pedidos com contatos e avisar manualmente uma vaga por e-mail.

UC23	Gerir formulários e termos	Administrador (ADMIN)	Formulários de anamnese, pesquisa e perguntas do prontuário (lista de perguntas com alerta de saúde; 1 PRONTUARIO ativo) e termos versionados LGPD, SAÚDE e de procedimento (1 ativo por escopo; imutáveis após aceite); painel de conformidade dos aceites.
UC24	Administrar o sistema	Administrador (ADMIN)	Usuários da equipe (link para definir senha, ativar/desativar), configurações, Branding, notificações, pré-visualização de e-mails e auditoria.
UC25	Executar jobs periódicos	Sistema / Cron externo, Serviços externos	POST /cron/run/<job>/ com X-Cron-Token (ou rodar_job no servidor) executa o job dentro do request: fila de e-mail (15 min), lembrete D-1, NPS, alerta de detrator, pacotes, aniversário, limpeza de status, retenção LGPD e housekeeping (procedures do Postgres), feriados; 500 quando o job falha; trilha com origem cron:<job>.
UC26	Receber webhooks	Serviços externos, Sistema / Cron externo	WhatsApp: handshake e eventos assinados (captura nota de NPS). Zenvia: status de entrega com IP permitido e/ou HMAC.
UC27	Agendar pela recepção	Administrador (ADMIN)	Buscar cliente ou cadastrar nova (telefone validado), escolher procedimento, profissional habilitado e horário do SlotService; valor com promoção ou combinado; atendimento nasce AGENDADO, auditado; aviso de ficha pendente.
UC28	Moderar depoimentos	Administrador (ADMIN)	No painel de NPS, aprovar (só com opt-in da cliente e comentário) ou retirar depoimentos do site; auditado.
UC29	Gerir autorizações de comunicação	Administrador (ADMIN)	Na ficha da cliente: ver o estado de cada finalidade × canal, revogar a pedido da cliente e registrar autorização com justificativa (origem PAINEL, autor); o histórico é preservado e o mais recente vale.
UC30	Assinar o feed iCal da agenda	Profissional, Administrador (ADMIN)	Gerar o link do feed iCal (no portal ou no painel): o link anterior é revogado e a URL aparece uma única vez; o banco guarda só o hash do token.

7. Modelo de Domínio (Diagrama de Classes)

Os atributos seguem os nomes das classes Python; no banco, tabelas e colunas seguem o padrão SQL do projeto (por exemplo, ativo → eh_ativo, buffer_minutos → intervalo_minutos). O nome físico de cada tabela está no dicionário de entidades (7.1).

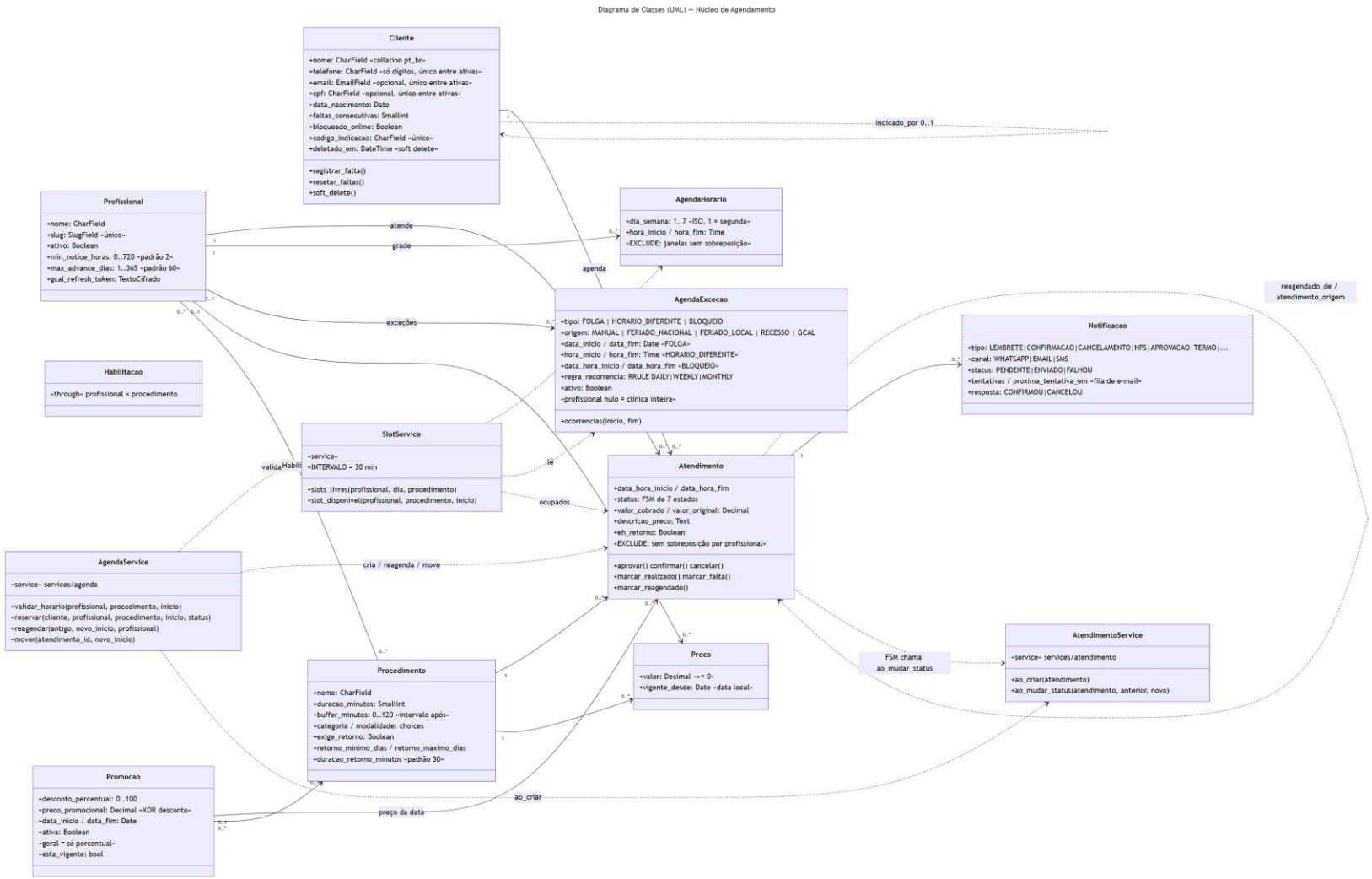


Figura 3 — Diagrama de Classes (UML): Núcleo de Agendamento.

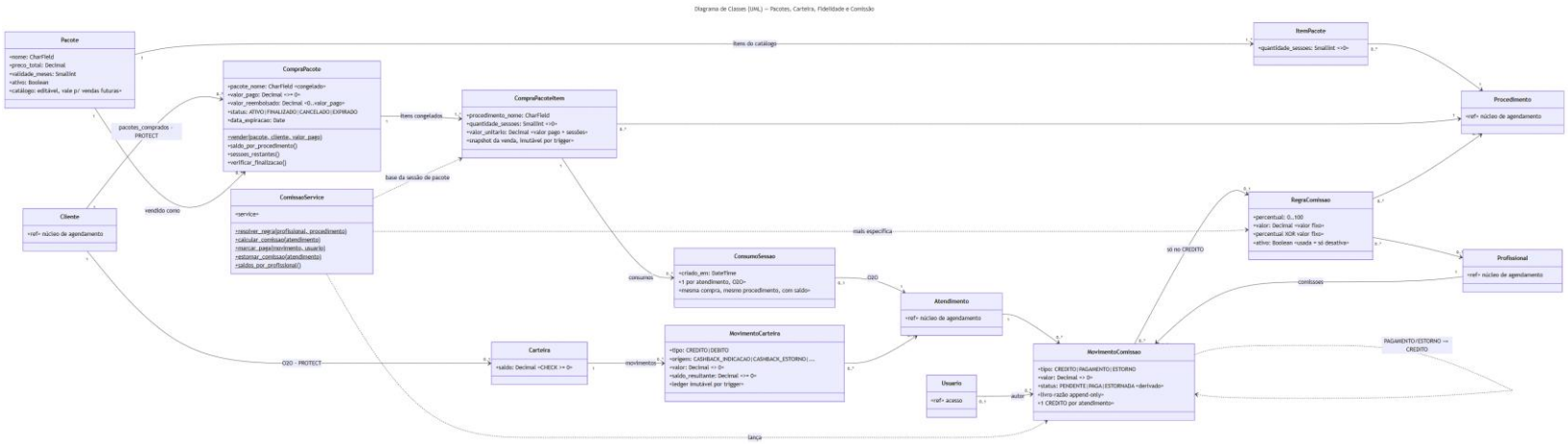


Figura 4 — Diagrama de Classes (UML): Pacotes, Carteira, Fidelidade e Comissão.

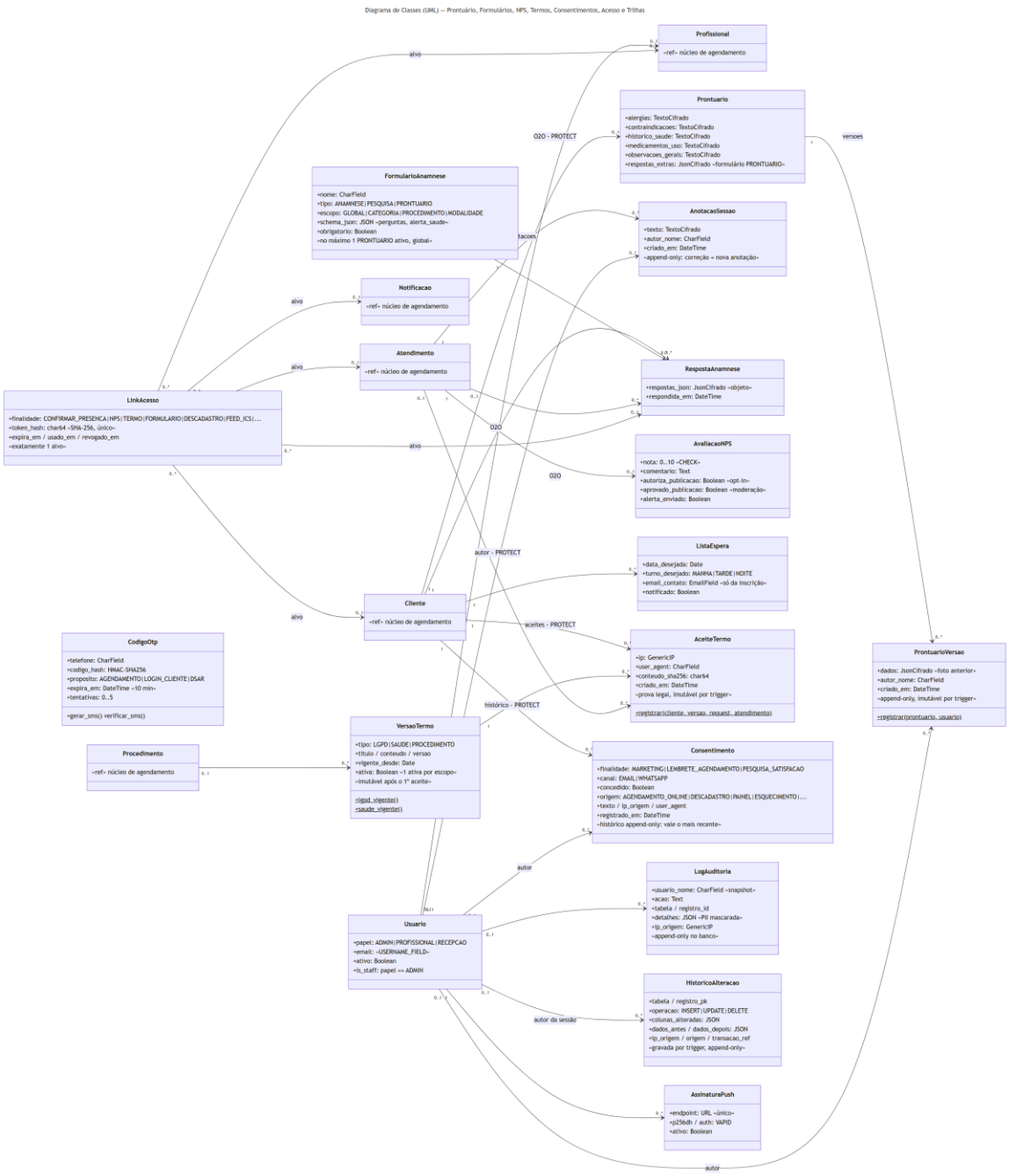


Figura 5 — Diagrama de Classes (UML): Prontuário, Formulários, NPS, Termos, Consentimentos, Acesso e Trilhas.

7.1 Dicionário de entidades

Entidade	Tabela	Descrição
Cliente	cliente	Cliente da clínica: identidade pelo celular (só dígitos, 10–11, único entre ativas); e-mail, CPF e demais dados pessoais opcionais (ausente = NULL); contador de faltas e bloqueio do agendamento online; indicação (código próprio + indicadora, base do cashback); exclusão lógica (deletado_em). As autorizações de comunicação ficam na tabela consentimento (histórico, 0050).

Profissional	profissional	Profissional que atende: antecedência mínima (0–720 h, padrão 2) e máxima (1–365 dias, padrão 60), dados de vitrine (especialidade, foto, biografia) e integração opcional com o Google Calendar (token de renovação cifrado). O feed iCal usa um link_acesso FEED_ICS.
AgendaHorario	agenda_horario	Grade semanal de atendimento do profissional: várias janelas por dia, sem sobreposição (EXCLUDE), dia_semana ISO (1 = segunda … 7 = domingo). Substitui disponibilidade_profissional (0048).
AgendaExcecao	agenda_excecao	Tudo o que muda a grade numa data (0048 unificou exceção, bloqueio e feriado): FOLGA (intervalo de datas; sem profissional = clínica inteira — feriado nacional/local ou recesso), HORARIO_DIFERENTE (substitui a grade num dia) e BLOQUEIO (instantes, pontual ou recorrente por RRULE DAILY/WEEKLY/MONTHLY; sem profissional = todos). Origem MANUAL, FERIADO_NACIONAL, FERIADO_LOCAL, RECESSO ou GCAL; inativa = registrada e ignorada.
Procedimento	procedimento	Serviço do catálogo: duração, intervalo após a sessão (0–120 min), categoria, modalidade, imagem e regra de retorno obrigatório (janela mínima/máxima em dias e duração do retorno, padrão 30 min).
Habilitacao	habilitacao	Liga profissional e procedimento (M2M through): só profissional habilitado realiza o procedimento; sem nenhuma habilitação cadastrada, todos realizam.
Preco	preco	Preço versionado por data de início de vigência (data local), base (sem profissional) ou por profissional; o atendimento usa o preço da data do atendimento (profissional > base).
Promocao	promocao	Promoção por período: desconto percentual (0–100) XOR preço fixo; procedimento nulo = promoção geral (só percentual vale). Aplica-se só quando reduz o valor.
Atendimento	atendimento	Agendamento/sessão: cliente, profissional, procedimento, período, preço gravado (valor cobrado, valor original, promoção e descrição), retorno (eh_retorno + atendimento de origem), atendimento que este substitui (reagendamento) e FSM de 7 estados. Sem token próprio: links públicos em link_acesso.
Notificacao	notificacao	Toda mensagem ligada a um atendimento (LEMBRETE, LEMBRETE_2H, CONFIRMACAO, CANCELAMENTO, NPS, PESQUISA, APROVACAO, TERMO) por canal (WhatsApp, SMS, e-mail) e status PENDENTE/ENVIADO/FALHOU. Também é a fila do e-mail transacional (tentativas, próxima tentativa; 0061); não guarda cópia de dado pessoal.
LinkAcesso	link_acesso	Link público com token (confirmar presença, NPS, termo, ficha, descadastro, feed iCal e o legado gerenciar agendamento): finalidade + exatamente 1 alvo; o banco guarda só o SHA-256 do token, a validade, o uso e a revogação (0049). O token em claro existe só na URL entregue.
Usuario	usuario	Usuário da equipe (login por e-mail): papel ADMIN, PROFISSIONAL ou RECEPCAO (sem login); is_staff = ADMIN; vínculo opcional 1:1 com Profissional; desativar em vez de excluir.
AssinaturaPush	assinatura_push	Inscrição Web Push (VAPID) de um usuário da equipe, para o aviso de novo agendamento.
LogAuditoria	log_auditoria	Trilha de auditoria das ações (LGPD art. 37): autor + snapshot "Nome <email>", ação, tabela, registro, detalhes com PII mascarada e IP. Append-only no banco (0059): só a purga com 180+ dias, a pseudonimização do esquecimento e o SET NULL

		do autor.
HistoricoAlteracao	historico_alteracao	Trilha de dados gravada por trigger (0056) nas 11 tabelas sensíveis: operação, colunas alteradas com antes/depois (senha redigida), autor, IP, origem (web, cron, comando, migração) e transação. Append-only; leitura auditada.
Consentimento	consentimento	Histórico append-only de autorizações de comunicação por finalidade × canal (MARKETING/E-MAIL, LEMBRETE_AGENDAMENTO/WHATSAPP, PESQUISA_SATISFACAO/WHATSAPP): concedido ou revogado, origem, texto exibido, IP, navegador, autor e data. Vale a linha mais recente do par; sem linha = não concedido (0050).
Prontuario	prontuario	Ficha base 1:1 da cliente preenchida pela equipe: alergias, contraindicações, histórico, medicamentos, observações e respostas do questionário do prontuário (formulário PRONTUARIO, 0051). Conteúdo cifrado em repouso (0060).
ProntuarioVersao	prontuario_versao	Histórico append-only do prontuário: foto do estado anterior a cada edição (cifrada), com autor e data.
AnotacaoSessao	anotacao_sessao	Anotação da sessão de um atendimento (texto cifrado), com autor preservado (PROTECT + snapshot do nome). Append-only: correção = nova anotação.
FormularioAnamnese	formulario	Questionário em lista de perguntas (key, tipo, rótulo, obrigatória, opções, alerta de saúde): ANAMNESE e PESQUISA respondidas pela cliente e PRONTUARIO (perguntas extras da ficha, preenchidas pela equipe — no máximo 1 ativo, sempre global e não obrigatório). Escopo global, categoria, procedimento ou modalidade. Tabela formulario.
RespostaAnamnese	resposta_formulario	Ficha respondida pela cliente (respostas cifradas), ligada ao atendimento; o convite por link vive em link_acesso (FORMULARIO, 60 dias). Tabela resposta_formulario.
VersaoTermo	versao_termo	Termo versionado: LGPD (Política de Privacidade), SAUDE (consentimento para dado de saúde, art. 11) ou PROCEDIMENTO (geral ou de um procedimento); 1 versão ativa por escopo; imutável depois do 1º aceite.
AceiteTermo	aceite_termo	Prova de aceite de termo: cliente, versão, atendimento, IP, navegador e SHA-256 do texto aceito. Imutável e nunca apagado.
CodigoOtp	codigo_otp	Desafio OTP de 6 dígitos guardado como HMAC-SHA256, preso ao telefone, com propósito AGENDAMENTO, LOGIN_CLIENTE ou DSAR, validade de 10 min e até 5 tentativas.
AvaliacaoNPS	avaliacao_nps	Avaliação NPS 0–10 de um atendimento: comentário, autorização de publicação da cliente, aprovação da clínica (só com a autorização) e alerta de detrator enviado.
ListaEspera	lista_espera	Pedido de aviso de vaga: procedimento, data, turno, profissional desejado opcional e e-mail de contato só da inscrição; 1 pedido pendente por cliente/procedimento/data.
Pacote	pacote	Catálogo de pacotes de sessões: valor total e validade em meses. Editável a qualquer momento — vale só para vendas futuras (o vendido fica congelado em compra_pacote_item).
ItemPacote	pacote_item	Item do catálogo do pacote: procedimento e quantidade de sessões. Tabela pacote_item.
CompraPacote	compra_pacote	Venda de pacote a uma cliente: nome do pacote congelado, valor pago, valor reembolsado, status ATIVO/FINALIZADO/CANCELADO/EXPIRADO e data de expiração.
CompraPacoteItem	compra_pacote_item	O que foi vendido (snapshot imutável, 0052): procedimento, nome, quantidade de sessões e valor unitário (valor pago ÷ sessões — base da comissão da sessão de pacote).

ConsumoSessao	consumo_sessao	Consumo de 1 sessão de um item da compra por um atendimento REALIZADO (OneToOne com o atendimento): mesmo procedimento, mesma compra, nunca retorno e só com saldo.
Carteira	carteira	Saldo de crédito da cliente (cashback de indicação e estorno); CHECK saldo ≥ 0.
MovimentoCarteira	movimento_carteira	Lançamento do livro-razão da carteira (crédito/débito, origem, saldo resultante, autor); imutável por trigger; 1 cashback por atendimento.
RegraComissao	regra_comissao	Regra de comissão por profissional e/ou procedimento: percentual (0–100) XOR valor fixo; regra já usada é protegida (só desativa).
MovimentoComissao	movimento_comissao	Livro-razão da comissão (0053): CREDITO (1 por atendimento realizado, com a regra), PAGAMENTO (baixa, com autor) e ESTORNO (cancelamento), os dois últimos referenciando o crédito. Status e saldo são derivados; o saldo pode ficar negativo (comissão paga e depois estornada).
Configuracao	configuracao	Chave-valor editável no painel: campos do Branding, e-mail de alertas da clínica e MAX_FALTAS_BLOQUEIO (opcional).
TimestampedMixin [ABSTRATO]	(abstract — sem tabela)	ABSTRATO: adiciona criado_em + atualizado_em com DEFAULT now() no banco (usado por Carteira e RegraComissao).

8. Diagrama de Estados — Atendimento (FSM)

O status do atendimento é governado por uma máquina de estados finitos; transições inválidas levantam exceção tipada (Atendimento.TransicaoInvalida). Estado inicial: PENDENTE.

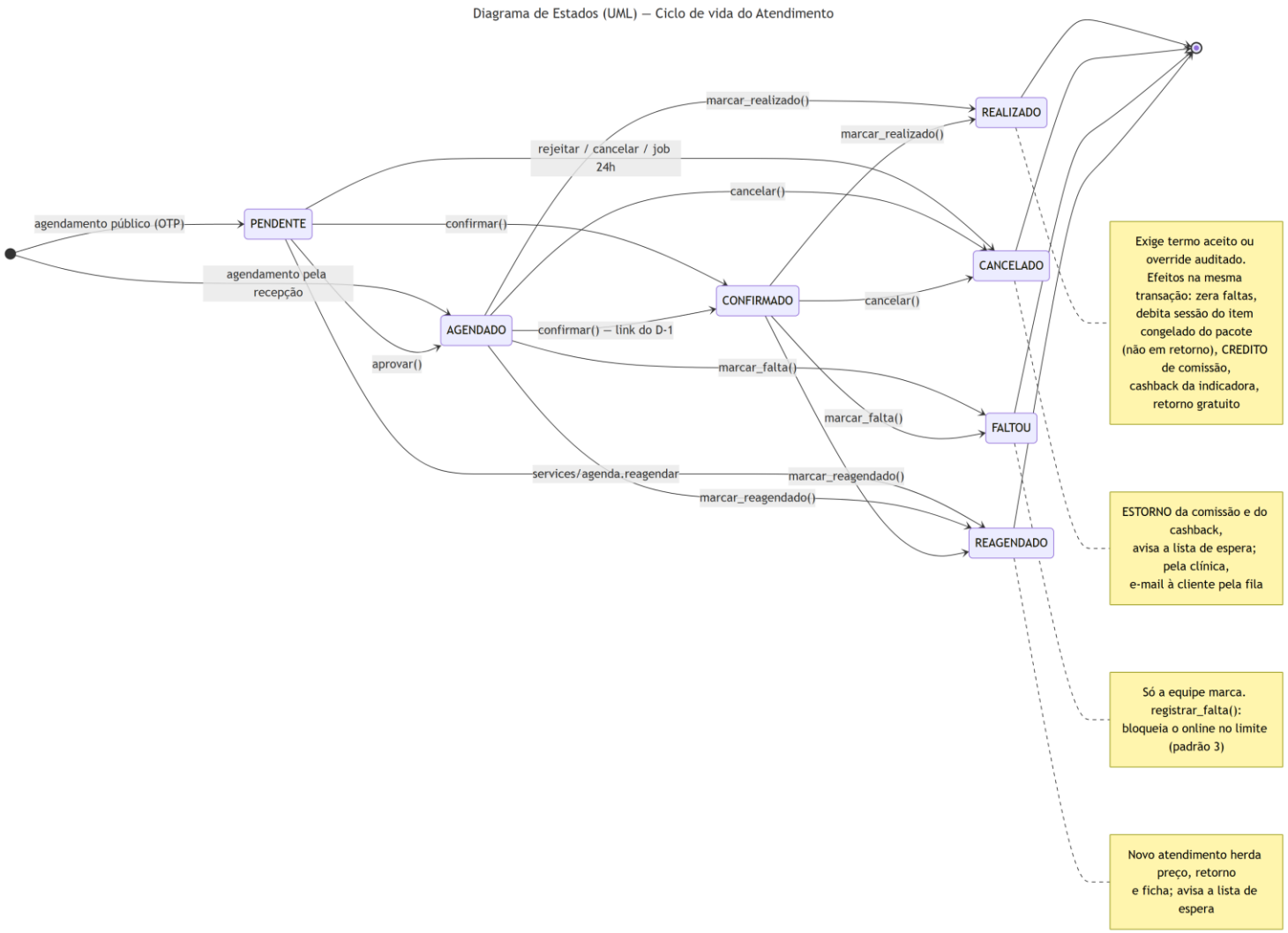


Figura 6 — Diagrama de Estados (UML): ciclo de vida do Atendimento.

8.1 Tabela de transições

Estado origem	Estado destino	Ação / gatilho
PENDENTE	AGENDADO	aprovar() — clínica aprova o pedido (painel ou portal)
PENDENTE	CONFIRMADO	confirmar()
PENDENTE	CANCELADO	cancelar() — rejeitar pedido, cliente cancela (portal) ou job limpeza_status (vencido há 24 h)
PENDENTE	REAGENDADO	marcar_reagendado() — services/agenda.reagendar
AGENDADO	CONFIRMADO	confirmar() — cliente confirma pelo link do lembrete D-1 ou equipe
AGENDADO	REALIZADO	marcar_realizado() — exige termo aceito ou override auditado
AGENDADO	CANCELADO	cancelar()
AGENDADO	FALTOU	marcar_falta() — só a equipe
AGENDADO	REAGENDADO	marcar_reagendado() — services/agenda.reagendar
CONFIRMADO	REALIZADO	marcar_realizado() — exige termo aceito ou override auditado
CONFIRMADO	CANCELADO	cancelar()
CONFIRMADO	FALTOU	marcar_falta() — só a equipe
CONFIRMADO	REAGENDADO	marcar_reagendado() — services/agenda.reagendar

8.2 Efeitos automáticos (services/atendimento / jobs)

- Toda transição: _transicionar trava a linha (select_for_update), valida TRANSICOES contra o status atual do banco, grava status + LogAuditoria e aplica os efeitos (services/atendimento.ao_mudar_status) na MESMA transação: efeito que falha desfaz a transição inteira. Transição inválida levanta Atendimento.TransicaoInvalida (a tela mostra a mensagem).
- Criação (services/agenda.reservar → ao_criar): push "Novo agendamento" ao profissional e sync com o Google Calendar no on_commit, best-effort.
- → REALIZADO, em ordem: zera faltas e desbloqueia a cliente; debita 1 sessão do item congelado do pacote que vence primeiro (nunca em retorno; validade na data da sessão); lança o CREDITO de comissão (base = valor cobrado, ou valor unitário congelado da sessão de pacote); libera o cashback da indicadora no 1º atendimento pago; cria o retorno obrigatório (PENDENTE, valor 0) se o procedimento exige.
- → FALTOU: registrar_falta — soma a falta e suspende o agendamento online no limite (padrão 3).
- → CANCELADO: lança o ESTORNO da comissão e estorna o cashback; vindo de um estado ativo, avisa a lista de espera. Cancelado pela clínica: e-mail à cliente (fila de e-mail).
- → REAGENDADO: vindo de um estado ativo, avisa a lista de espera.
- Lista de espera: seleção dos compatíveis em savepoint na transação de quem liberou a vaga; e-mail e WhatsApp no on_commit; falha no aviso nunca desfaz o cancelamento.
- Aprovação (PENDENTE → AGENDADO) e rejeição geram e-mail à cliente pela fila de e-mail (Notificacao EMAIL na mesma transação, envio no on_commit, reenvio pelo job emails).
- NPS e lembrete D-1 não são disparados por transição: vêm dos jobs nps_24h e lembrete_diario (cron HTTP).
- PENDENTE vencido há 24 h → CANCELADO pelo job limpeza_status; AGENDADO/CONFIRMADO sem desfecho só vão para o log (a equipe decide falta ou realizado).
- Toda escrita em atendimento entra na trilha historico_alteracao (trigger) com autor, IP e origem.

9. Diagrama de Sequência — Agendamento com OTP

Fluxo do agendamento público: verificação do celular por OTP via SMS (exigida em todo agendamento), aceites e consentimentos com prova, controle de concorrência do horário e criação transacional do atendimento PENDENTE.

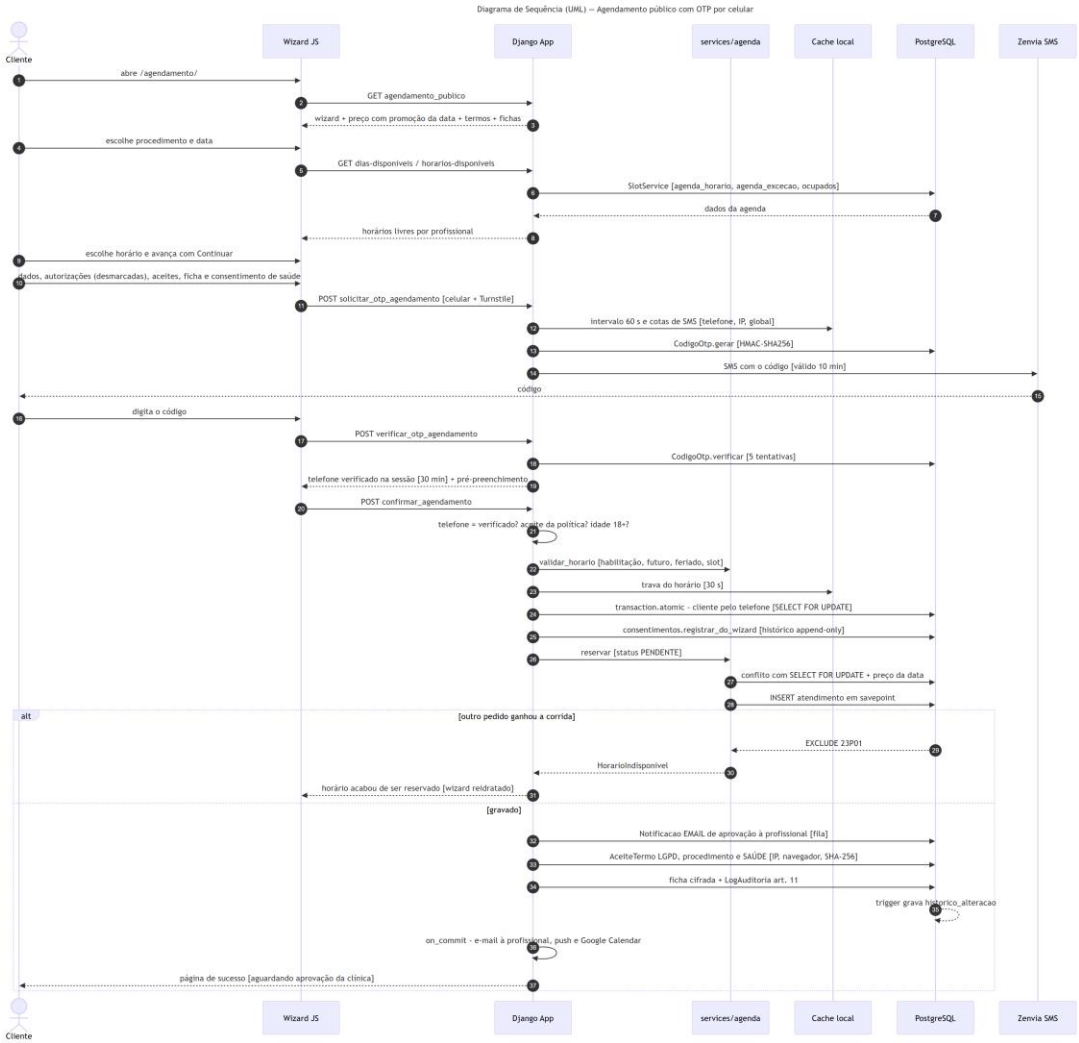


Figura 7 — Diagrama de Sequência (UML): agendamento público com OTP.

9.1 Passo a passo

1. A cliente abre /agendamento/; o wizard recebe o catálogo com o preço da data (promoção), os termos e as fichas aplicáveis.
2. Escolhe procedimento e data; o wizard consulta /ajax/dias-disponiveis/ e /ajax/horarios-disponiveis/ (SlotService sobre agenda_horario, agenda_excecao e atendimentos ativos).
3. Escolhe o horário e o profissional e avança com o botão Continuar.
4. Informa nome, celular, nascimento e e-mail opcional; marca (nunca pré-marcadas) as autorizações de comunicação; aceita a Política de Privacidade e os termos; responde a ficha e o consentimento de saúde.
5. Pede o código: o servidor valida o Turnstile, recusa fixo, confere intervalo de 60 s e cotas de SMS e grava o CodigoOtp (HMAC-SHA256); a Zenvia entrega o SMS.

6. Digita o código: até 5 tentativas; o telefone fica verificado na sessão por 30 min e o cadastro daquele telefone pré-preenche o formulário.
7. Confirma: o servidor exige o telefone do formulário = o verificado, o aceite da política e idade ≥ 18.
8. services/agenda.validar_horario revalida habilitação, horário futuro, feriado/recesso e o slot.
9. Trava do horário no cache (30 s) e transaction.atomic: cliente pelo telefone (SELECT FOR UPDATE), recusa se bloqueada online.
10. services/consentimentos.registrar_do_wizard grava as concessões/revogações (histórico append-only).
11. services/agenda.reservar: conflito com SELECT FOR UPDATE, preço da data e INSERT do atendimento PENDENTE num savepoint (corrida perdida para o EXCLUDE vira HorarioIndisponivel).
12. Na mesma transação: Notificacao EMAIL de aprovação à profissional (fila), AceiteTermo LGPD, de procedimento e SAÚDE (IP, navegador, SHA-256), fichas cifradas e LogAuditoria do consentimento art. 11; a trilha historico_alteracao registra o atendimento.
13. Após o commit: e-mail à profissional, push e Google Calendar (best-effort); a trava do cache é liberada.
14. A cliente vê a página de sucesso (aguardando aprovação da clínica); a clínica aprova (AGENDADO + e-mail) ou rejeita.

10. Arquitetura e Integrações

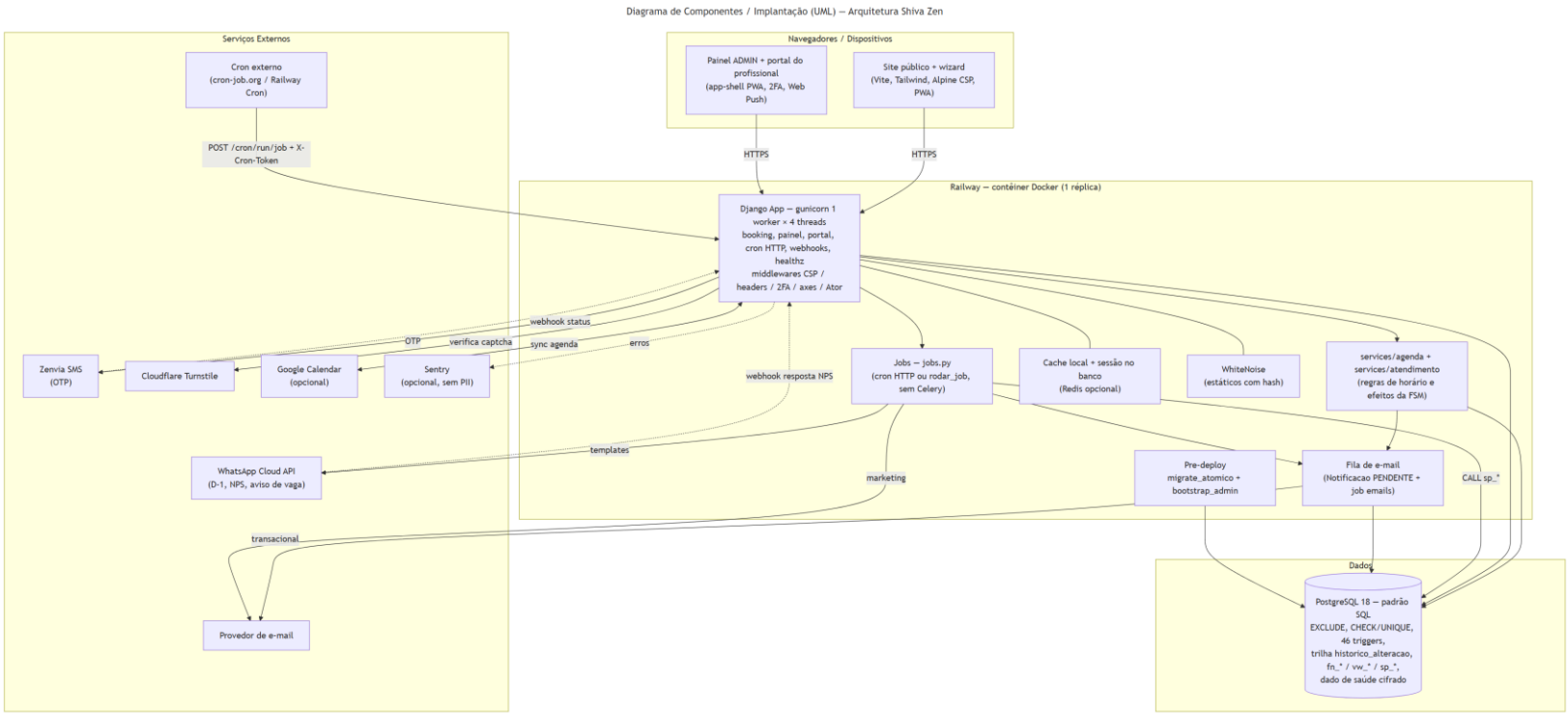


Figura 8 — Diagrama de Componentes / Implantação (UML).

10.1 Componentes

Componente	Papel
Navegador (site público + wizard)	Páginas server-render com Vite, Tailwind CSS v4, Alpine.js (build CSP) e componentes django-cotton; uma entrada JS por tela; fontes locais; PWA com service worker (só páginas públicas).
Navegador (painel ADMIN + portal do profissional)	App-shell PWA da equipe com 2FA, Django Forms, calendário (FullCalendar) e Web Push.
Django App (gunicorn)	Monólito Django 5.2: views (validação + permissão) → services/utils (regra de negócio) → models (FSM, managers, constraints). Middlewares de CSP com nonce, headers, 2FA, axes, rate-limit e ContextoBancoMiddleware (Ator da requisição).
services/agenda e services/atendimento	Fonte única das regras de horário (validar_horario, reservar, reagendar, mover) e dos efeitos de criar/mudar status do atendimento, chamados explicitamente na transação da FSM.
Jobs (jobs.py, jobs_manutencao.py)	Funções chamadas pelo cron HTTP /cron/run/<job>/ (X-Cron-Token) ou por manage.py rodar_job; sem Celery nem worker de fila.
Fila de e-mail (notificacao)	E-mail transacional gravado como Notificacao PENDENTE na transação, enviado no on_commit e reenviado pelo job emails com espera crescente.
PostgreSQL 18	36 tabelas de domínio no padrão SQL; invariantes por EXCLUDE, CHECK, UNIQUE parciais e 46 triggers; trilha historico_alteracao; 23 funções fn_*, 9 views vw_* de relatório e 4 procedures sp_* (retenção/LGPD, expiração de pacotes); extensões btree_gist, pg_trgm e unaccent.
Cache e sessão	LocMemCache + sessão no banco (1 worker); REDIS_URL troca para django-redis.
WhiteNoise	Estáticos comprimidos e com hash servidos pelo próprio processo.
Pre-deploy (Railway)	migrate_atomico (todas as migrations numa transação, com lock_timeout) + bootstrap_admin; imagem Docker multi-stage com usuário não-root e healthcheck.

10.2 Integrações externas

Serviço	Uso
Zenvia SMS	OTP do agendamento, do "Meus agendamentos" e do DSAR (só celular), com cotas; webhook de status autenticado. Sem configuração o agendamento online fecha e o botão Agendar leva ao WhatsApp.
WhatsApp Cloud API (Meta)	Templates de lembrete D-1, NPS e aviso de vaga; webhook assinado (X-Hub-Signature-256) captura a nota do NPS.
E-mail (backend Django)	Transacional pela fila (aprovação, rejeição, cancelamento, aviso à profissional), termos, pacote expirando, reset/convite de senha e marketing com List-Unsubscribe.
Web Push (VAPID)	Aviso de novo agendamento ao profissional.
Google Calendar	Push do atendimento novo e importação de eventos como bloqueio (OAuth por profissional, token cifrado; opcional).
Cloudflare Turnstile	Captcha no pedido de código OTP.
Sentry	Erros e transações amostradas sem PII (scrubber de contato, saúde e tokens); opcional.

10.3 Rotas

Área	Rota	Função
Site público	/, /quem-somos/, /equipe/, /especialidades/, /galeria/, /depoimentos/, /promocoes/	Páginas institucionais; depoimentos só com autorização + aprovação; promoções com o mesmo preço do agendamento
Site público	/servicos/faciais/, /servicos/corporais/, /servicos/detalhe/<slug>/	Catálogo de serviços
Site público	/contato/, /termos-de-uso/, /politica-de-privacidade/	Contato (e-mail do Branding) e textos

		legais
Site público	/lista-espera/ (+ sucesso/)	Pedido de aviso de vaga
Site público	/sitemap.xml, /robots.txt, /manifest.json, /sw.js, /favicon.ico	SEO e PWA
Agendamento	/agendamento/, /agendar/<slug>/, /embed/agendar/	Wizard (geral, direto por profissional, widget para iframe)
Agendamento	/ajax/dias-disponiveis/, /ajax/horarios-disponiveis/	Dias do mês e horários livres (SlotService)
Agendamento	POST /agendamento/otp/solicitar/, POST /agendamento/otp/verificar/	Código OTP do celular (Turnstile quando configurado)
Agendamento	POST /agendamento/confirmar/, /agendamento/sucesso/	Grava o atendimento PENDENTE
Cliente	/meus-agendamentos/ (+ otp/enviar/, otp/verificar/, sair/)	Portal da cliente (código sempre ao celular)
Cliente	/meus-agendamentos/<id>/reagendar/ (+ <id>/horarios/), POST /ajax/cancelar-agendamento/	Reagendar e cancelar pela sessão do portal
Cliente	/reagendar/<token>/ (+ horarios/)	Reagendar pelo link legado (nenhum link novo é emitido)
Cliente	/confirmar/<token>/, /termo/<token>/, /nps/<token>/	Confirmar presença (D-1), aceitar termos, responder NPS
Cliente	/anamnese/<token>/, /pesquisa/<token>/ (+ obrigado/)	Ficha e pesquisa por link (mantidas, hoje sem produtor de link)
Cliente	/lgpd/meus-dados/, /lgpd/unsubscribe/<token>/, /lgpd/aceitar-cookies/	DSAR com OTP, descadastro, aviso de cookies
Equipe	/admin-login/, /admin-logout/, /admin-login/recuperar/…	Login da equipe (logout só via POST) e reset de senha
Equipe	/painel/seguranca/2fa/ (+ verificar/, challenge/)	Cadastro e desafio TOTP
Equipe	/profissional/ (+ atendimento/<pk>/{realizado,anotar,aprovar,rejeitar}/, calendario/novo-link/)	Portal do profissional e link do próprio feed iCal
Equipe	/agenda/<slug>/feed.ics?token=	Feed iCal do profissional
Painel	/painel/, /painel/overview/	Dashboard
Painel	/painel/agendamentos/ (+ novo/, bulk/, <pk>/aprovar|rejeitar|termo-link|valor/), /painel/atualizar-status/	Agenda em lista, agendamento interno, aprovação, link do termo, valor cobrado, mudança de status
Painel	/painel/calendario/ (+ eventos/, mover/)	Calendário com arrastar-e-soltar
Painel	/painel/clientes/, /painel/clientes/<pk>/	Clientes e ficha (pacotes, alertas, autorizações de comunicação, histórico)
Painel	/painel/prontuario/ (+ <cliente_id>/, salvar/), /painel/anotacao/<id>/salvar/	Prontuário com histórico de versões e anotações
Painel	/painel/profissionais/… (+ excecoes/, ics/novo-token/), /painel/bloqueios/…	Profissionais, exceções de agenda, bloqueios e link do feed iCal
Painel	/painel/procedimentos/…, /painel/pacotes/… (+ vender/, compras/<pk>/cancelar/), /painel/promocoes/… (+ disparar/)	Catálogo, pacotes e promoções
Painel	/painel/financeiro/, /painel/comissoes/ (+ <pk>/pagar/), /painel/nps/ (+ publicacao/), /painel/exportar-relatorio/	Relatórios, comissões, NPS e moderação de depoimentos, Excel
Painel	/painel/lista-espera/ (+ notificar/), /painel/anamneses/…, /painel/termos/ (+ criar/, compliance/)	Lista de espera, formulários e termos
Painel	/painel/notificacoes/, /painel/auditoria/, /painel/usuarios/…, /painel/configuracoes/…, /painel/branding/, /painel/email-preview/	Sistema
Painel	/painel/integrations/google/{connect,callback,pull}/…, /webpush/…, /django-admin-sv/	Google Calendar, Web Push e Django admin (só ADMIN com 2FA verificado)

Infraestrutura	GET/POST /api/whatsapp/webhook/, POST /api/zenvia/webhook/	Webhooks autenticados (Meta e Zenvia)
Infraestrutura	POST /cron/run/<job>/	Jobs periódicos (header X-Cron-Token)
Infraestrutura	/healthz/, /health/	Liveness e readiness

Histórico de Versões

Versão	Data	Descrição
2.1	21/06/2026	Documento de requisitos + modelagem UML gerado a partir do código (pós-auditoria SWE de backend e migração do front-end para base_v2).
2.2	23/09/2026	Atualização pós-auditoria pré-produção: OTP obrigatório em todo agendamento, consentimentos LGPD/art. 11 com prova de aceite imutável, 2FA obrigatório para ADMIN, histórico do prontuário, agendamento interno, deploy por Docker + migração atômica (migrations 0040–0046).
2.3	28/10/2026	Atualização pós-revisão de outubro/2026 (migrations 0047–0061): termo de saúde, agenda unificada (agenda_horario + agenda_excecao), links públicos em hash (link_acesso), consentimentos com histórico, questionário do prontuário como formulário PRONTUARIO, pacote congelado na venda (compra_pacote_item), comissão como livro-razão, padrão SQL de nomes, lógica no banco (triggers, funções, views e procedures), trilhas imutáveis, cifragem do dado de saúde, fila de e-mail na notificação e saída do Celery (jobs.py/rodar_job); services/agenda e services/atendimento, Ator da requisição, Django Forms no painel, wizard com botão Continuar e PWA. Diagramas UML revisados e tabela de rotas.